

XSS in Skype for iOS — Superevr

XSS in Skype for iOS — Superevr - superevr, Superevr.

- Published: 2011-09-19
- Original: <<https://superevr.com/blog/2011/xss-in-skype-for-ios/>>
- Preserved from: <https://superevr.com/blog/2011/xss-in-skype-for-ios/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Skype for iOS contains an XSS vulnerability that allows attackers steal information.

A Cross-Site Scripting vulnerability exists in the "Chat Message" window in Skype 3.0.1 and earlier versions for iPhone and iPod Touch devices.

Skype uses a locally stored HTML file to display chat messages from other Skype users, but it fails to properly encode the incoming users "Full Name", allowing an attacker to craft malicious JavaScript code that runs when the victim views the message.

AT&T 3G

1:02 AM

71 % 

Chats

"><iframe src=""...



ChatMessagesWebViewTem
plate.html



mphone

OK

Type message here



Contacts



Chats



Call



History



My Info

To demonstrate the vulnerability, I captured a photo of a simple javascript alert() running within Skype.

Executing arbitrary Javascript code is one thing, but I found that Skype also improperly defines the URI scheme used by the built-in webkit browser for Skype. Usually you will see the scheme set to something like, "about:blank" or "skype-randomtoken", but in this case it is actually set to "file:///". This gives an attacker access to the users file system, and an attacker can access any file that the application itself would be able to access.

File system access is partially mitigated by the iOS Application sandbox that Apple has implemented, preventing an attacker from accessing certain sensitive files. However, every iOS application has access to the users AddressBook, and Skype is no exception. **I created a proof of concept injection and attack that shows that a users AddressBook can indeed be stolen from an iPhone or iPod touch with this vulnerability.**

To further demonstrate the issue, I have recorded a video of this scenario. Please use the comments section below for your questions.

http://www.youtube.com/watch?v=Ou_lir2SkII



AT&T



12:31 AM



77%



All

New (1)

Today



<iframe id=m src=http...

Do you like XSS?



Contacts



1

Chats



Call



History



My Info

AT&T



12:33 AM

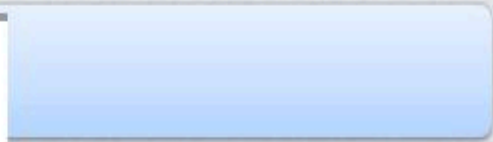
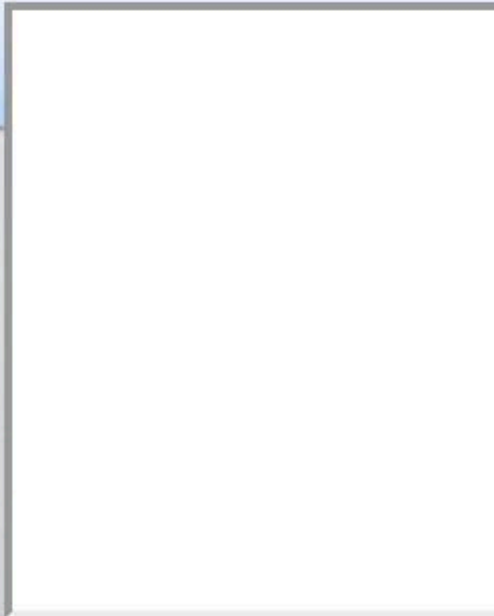


76%



Chats

<iframe id=m src=...



Type message here



Contacts



Chats



Call



History



My Info

Archived from <https://superevr.com/blog/2011/xss-in-skype-for-ios/>. Rendered offline from the local Markdown copy.